

QUẢN LÝ RỦI RO BẢO MẬT CHO HỆ THỐNG IoT

QUY MÔ NHỎ

Mã học phần	INT4410
Lớp học phần	
Giảng viên hướng dẫn	Hồ Nhật Minh
Sinh viên/Nhóm	Võ Nguyễn Duyên
Thành viên - MSSV	Võ Nguyễn Duyên - 231A010722
Link repo GitHub	vonguyenduyen512-oss/231A010722-vo-nguyen-duyen-quan-ly-rui-ro-iot : Bao cao tieu luan cuoi ky - Quan ly rui ro bao mat cho he thong IoT quy mo nho
Ngày nộp	24/07/2026



Bài toán: nhiều điểm kết nối, nhiều bề mặt tấn công

WHY IT MATTERS

Một thiết bị yếu có thể trở thành điểm vào của cả hệ thống.

Gateway, tài khoản quản trị, firmware và kết nối từ xa cùng tạo nên chuỗi rủi ro liên kết.

Mục tiêu của đề tài là biến rủi ro thành danh sách ưu tiên có thể hành động.

01

Xác định & phân loại tài sản

02

Nhận diện mối đe dọa và lỗ hổng

03

Xây dựng Risk Register + ma trận 5x5

04

Đề xuất biện pháp cho rủi ro ưu tiên

05

Thiết kế checklist kiểm tra định kỳ

MÔ HÌNH

Hệ thống IoT quy mô nhỏ

Hộ gia đình / phòng thí nghiệm, thiết bị–gateway–cloud–ứng dụng.

PHƯƠNG PHÁP

Định tính theo tài sản

$\text{Risk} = \text{Likelihood} \times \text{Impact}$,
chấm điểm trên ma trận 5×5.

THAM CHIẾU

OWASP + NIST

IoT ISVS, ISTG, IoT Project và
NIST SP 800-30.

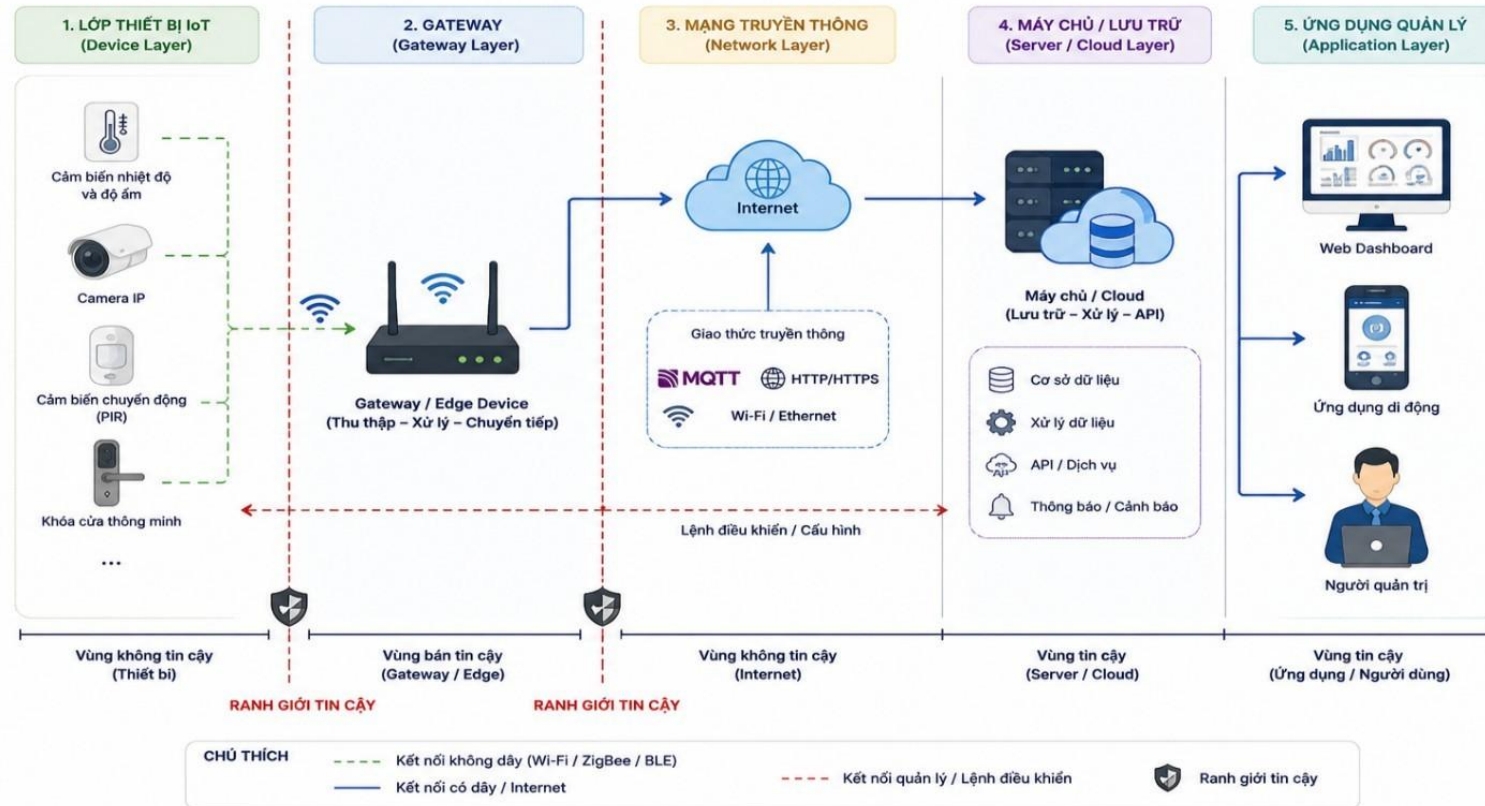
NGUYÊN TẮC THỬ NGHIỆM

01 Chỉ mô phỏng trong môi trường học tập

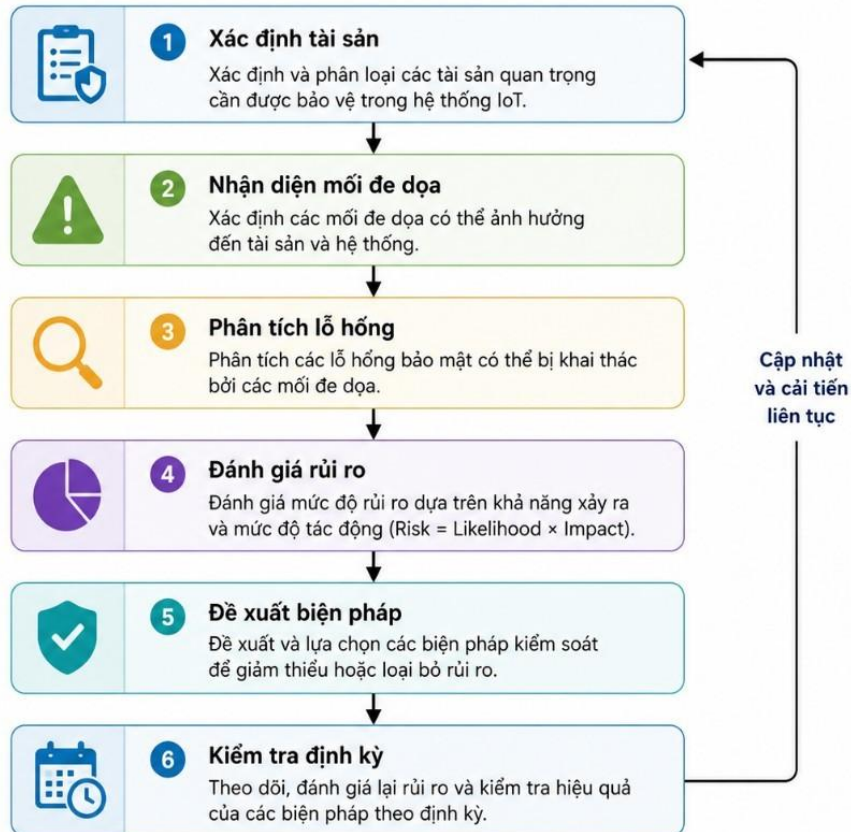
02 Không tấn công hệ thống thực tế

03 Không sử dụng dữ liệu cá nhân thật

KIẾN TRÚC TỔNG THỂ HỆ THỐNG IoT QUY MÔ NHỎ

DEVIC
EGATEW
AYNETWO
RKCLOU
DAPPLICA
TION

Hình 2.2. Quy trình quản lý rủi ro

**CÔNG THỨC
CHẤM ĐIỂM**

$$\text{RISK} = \text{LIKELIHOOD} \times \text{IMPACT}$$

Khả năng xảy ra và mức độ tác động đều chấm trên thang 1–5.

20–25**NGHIÊM TRỌNG****15–19****RẤT CAO****10–14****CAO****05–09****TRUNG BÌNH****01–04****THẤP**

Bảng 6.1. Tài sản và dữ liệu cần bảo vệ

Đề tài 35 - Quản lý rủi ro bảo mật cho hệ thống IoT quy mô nhỏ - Võ Nguyễn Duyên - 231A010722

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Gateway/Edge Device	Đội vận hành hệ thống	Rất cao (5/5)	Integrity, Availability	Điểm trung chuyển giữa thiết bị và máy chủ; ảnh hưởng toàn hệ thống nếu bị chiếm quyền
Tài khoản quản trị	Quản trị viên hệ thống	Rất cao (5/5)	Confidentiality, Integrity	Quyền truy cập cao nhất, mục tiêu hàng đầu của tấn công
Cơ sở dữ liệu (Database)	Quản trị viên/Máy chủ	Rất cao (5/5)	Confidentiality, Integrity, Availability	Lưu trữ dữ liệu cảm biến và thông tin tài khoản người dùng
Firmware thiết bị	Nhà sản xuất/Người dùng	Cao (4/5)	Integrity, Availability	Ảnh hưởng đến hoạt động và bảo mật lâu dài của thiết bị
Ứng dụng quản lý & Máy chủ	Quản trị viên/Người dùng	Cao (4/5)	Confidentiality, Integrity	Giao diện điều khiển và giám sát toàn bộ hệ thống IoT
Khóa cửa thông minh	Người dùng cuối (chủ nhà)	Rất cao (5/5)	Integrity, Availability	Liên quan trực tiếp đến an toàn vật lý và tài sản của người dùng

Tổng số tài sản:

6

4

tài sản mức RẤT CAO

2

tài sản mức CAO

C • I • A

ba yêu cầu bảo mật cốt lõi

6/6

có chủ thể chịu trách nhiệm

06 / RISK REGISTER

Toàn bộ 6 rủi ro đều nằm ở vùng ưu tiên cao nhất

0
7

PHÂN BỐ MỨC ĐỘ

2
Nghiêm trọng

33%

4
Rất cao

67%

Không có rủi ro ở mức Cao,
Trung bình hoặc Thấp.

R-01

20

Gateway chưa cập nhật
firmware

R-04

16

Firmware lỗi thời / có CVE

R-02

20

Tài khoản yếu, không có
MFA

R-05

16

Truy cập từ xa thiếu VPN

R-03

16

Camera còn mật khẩu mặc
định

R-06

15

Replay attack với khóa
thông minh

Ma trận đánh giá rủi ro 5×5 (minh họa cho Hình 5.3)

Điểm = Khả năng x Tác động. ID rủi ro trong mỗi ô tham chiếu từ sheet RiskRegister_6.2-6.3

Khả năng \ Tác động		1	2	3	4	5
5	5	10	15	20 (R-02)	25	
4	4	8	12	16 (R-03, R-04, R-05)	20 (R-01)	
3	3	6	9	12	15 (R-06)	
2	2	4	6	8	10	
1	1	2	3	4	5	

ƯU
TIÊN 1

R-01 và R-02 cần xử lý trước; các rủi ro còn lại vẫn phải triển khai kiểm soát ngay.

R-01

20

GATEWAY

Firmware không được cập nhật định kỳ

KIỂM SOÁT ĐỀ XUẤT

- ✓ Lập lịch cập nhật firmware
- ✓ Theo dõi security advisory
- ✓ Kiểm thử trước khi triển khai

RỦI RO CÒN
LẠI

CAO

R-02

20

TÀI KHOẢN QUẢN TRỊ

Mật khẩu yếu và chưa áp dụng MFA

KIỂM SOÁT ĐỀ XUẤT

- ✓ Mật khẩu mạnh và duy nhất
- ✓ Bắt buộc MFA
- ✓ Khóa sau nhiều lần đăng nhập sai

RỦI RO CÒN
LẠI

THẤP

R-03

CAMERA IP

Mật khẩu mặc định

Đổi mật khẩu • tắt tài khoản mặc định • VLAN riêng

R-04

FIRMWARE

Thiết bị lỗi thời / CVE

Thay thiết bị hết hỗ trợ • quét lỗ hổng • vá ngay

R-05

SERVER / APP

Truy cập từ xa mở

VPN • IP allowlist • MFA • giám sát log

R-06

KHÓA THÔNG MINH

Replay attack

Mã hóa • rolling code • cảnh báo bất thường

MỤC TIÊU SAU XỬ LÝ: đưa cả 4 rủi ro về mức THẤP

02

HÀNG TUẦN

01

Mật khẩu mặc định

02

Log truy cập bất thường

Phát hiện sớm dấu hiệu chiếm quyền.

02

HÀNG THÁNG

01

Phiên bản firmware

02

Cấu hình MFA

Duy trì bản vá và xác thực mạnh.

02

HÀNG QUÝ

01

Mã hóa đường truyền

02

Phân đoạn mạng VLAN

Xác nhận kiểm soát nền tảng còn hiệu lực.

KẾT LUẬN

Từ danh sách rủi ro
đến kế hoạch hành động.

Đề tài hoàn thành đủ 5 mục tiêu và tạo được bộ công cụ quản lý rủi ro có thể tái sử dụng cho hệ thống IoT quy mô nhỏ.

6 TÀI
SẢN

6 RỦI RO

6 KIỂM
SOÁT

6 CHECK
LIST

HƯỚNG PHÁT TRIỂN

- Thử nghiệm trên thiết bị IoT vật lý
- Tích hợp SIEM / IDS / IPS
- Kiểm thử theo OWASP ISTG và mở rộng theo NIST CSF

CẢM ƠN THẦY VÀ CÁC BẠN ĐÃ LẮNG NGHE

